Computers & Security 154 (2025) 104439

Contents lists available at ScienceDirect

Computers & Security

journal homepage: www.elsevier.com/locate/cose

Full length article

A novel proactive and dynamic cyber risk assessment methodology

Pavlos Cheimonidis *, Konstantinos Rantos

Democritus University of Thrace, Department of Informatics, Kavala, 654 04, Greece

ARTICLE INFO

Keywords:
Cybersecurity
Cyber risk assessment
Dynamic risk assessment
Bayesian networks
Industrial control systems

ABSTRACT

In today's operational environment, organizations face numerous cybersecurity challenges and risks. This paper presents a novel risk assessment methodology designed to assess cyber risks in a proactive and dynamic manner. Our approach gathers information from both the organization's internal environment and cybersecurity-related open sources. It then converts the collected qualitative data into numerical form by applying predefined mapping rules, including categorical assignments and frequency-based quantification. These numerical values are then integrated with other quantitative data using a probabilistic method. Subsequently, all this information is integrated into a Bayesian network model to dynamically estimate the probability of success of a cyber attack. This probability, combined with the impact assessments of the organization's assets, is used to provide risk estimations. By incorporating the Exploit Prediction Scoring System, our model is capable of delivering not only dynamic but also proactive risk assessments. To validate the effectiveness of the proposed methodology, we present a use case that demonstrates its application in assessing risk within a SCADA environment.

1. Introduction

Supervisory Control and Data Acquisition (SCADA) systems are essential for controlling and monitoring operations within numerous Industrial Control System (ICS) environments (Tariq et al., 2019). The integration of Information and Communications Technology (ICT) within SCADA environments has significantly enhanced the capabilities of ICS; however, it has simultaneously exposed these systems to a new spectrum of cyber threats and risks (Kang et al., 2009). As a result, the cybersecurity challenges associated with ICS have become more severe than ever before (Nicholson et al., 2012). Consequently, conducting thorough (cyber) risk assessments within ICS is imperative to identify potential threats and risks, and to develop effective mitigation strategies (Ren et al., 2021).

Risk assessment (RA) methodologies based on conventional standardized frameworks, such as ISO 31000:2018 (International Organization for Standardization, 2018) and the NIST 800-37 Risk Management Framework (Joint Task Force Transformation Initiative, 2018), are insufficient in ensuring that an organization's security posture meets contemporary requirements. These frameworks are inherently rigid and struggle to accommodate the dynamic and evolving nature of modern operational environments (Linkov et al., 2014). Traditional RA methodologies, being static and inflexible, are inadequate for addressing the rapidly shifting threat landscape, often resulting in misperceptions regarding risks and their potential consequences (Naumov and Kabanov, 2016). Furthermore, conventional RA techniques mostly rely on qualitative assessments, which are inherently subjective and may lack the precision (Henley and Kumamoto, 2000).

Given the increasing frequency and sophistication of malicious activities from diverse sources, organizations must adopt adaptive, real-time risk assessment approaches capable of effectively responding to emerging threats (Sánchez-Zas et al., 2023). In our previous work (Cheimonidis and Rantos, 2023), we emphasized the advantages of Dynamic Risk Assessment (DRA) models, which primarily collect and analyze data from their operational environment or cybersecurity-related open sources to generate dynamic and quantitative risk assessments. These quantitative approaches are particularly well-suited for risk assessment in the ICS domain Qin et al. (2021).

Moreover, these models have demonstrated their ability to adapt to evolving threats, providing accurate and timely risk evaluations, thereby strengthening an organization's resilience against cybersecurity threats. Among DRA methodologies, those employing Bayesian networks as their primary analytical framework are particularly prevalent in both ICT and ICS domains (Cheimonidis and Rantos, 2023). However, a notable limitation of current DRA approaches proposed in the literature is their inability to provide proactive functionalities, limiting their effectiveness in anticipating risks (Cheimonidis and Rantos, 2023).

In this study, we present a novel DRA methodology that employs Bayesian networks as the primary analysis method in order to dynamically and proactively assess risk. Our approach collects and analyzes

* Corresponding author.
E-mail addresses: pcheimon@cs.duth.gr (P. Cheimonidis), krantos@cs.duth.gr (K. Rantos).

https://doi.org/10.1016/j.cose.2025.104439
Received 16 October 2024; Received in revised form 18 February 2025; Accepted 11 March 2025
Available online 21 March 2025
0167-4048/© 2025 The Author(s). Published by Elsevier Ltd. This is an open access article under the CC BY license (http://creativecommons.org/licenses/by/4.0/).

data from reliable open-sources to produce quantitative results. In more detail, our methodology leverages Common Vulnerabilities and Exposures (CVE) records (The MITRE Corporation, 2024) to obtain Exploit Prediction Scoring System (EPSS) scores (Anon, 2024c) integrating the probability of exploitation produced by the EPSS into our model. Additionally, it utilizes the identified CVEs to gather associated Common Weakness Enumeration (CWE) records (Anon, 2024b), which are subsequently used to detect corresponding Common Attack Pattern Enumeration and Classification (CAPEC) IDs. This process enables the identification of the likelihood of a successful attack as indicated by the CAPEC framework. Finally, our approach employs the identified CAPEC IDs to map related Techniques from the MITRE ATT&CK framework, which are crucial for detecting Advanced Persistent Threat (APT) Groups.

The qualitative data collected from CAPEC, is transformed into quantitative form and combined with EPSS scores through a probabilistic method to generate a threat score for each asset. Additionally, qualitative data related to APT Groups from the MITRE ATT&CK framework is transformed into numerical values, which are referred to as APT Groups Indicators. This conversion of qualitative data into quantitative form is necessary for its use in the Bayesian network model.

The aforementioned data (Threat Score, APT Groups Indicators), along with information about the network topology of the target environment and potential attackers' movements (attack paths), are integrated into a Bayesian network model, hereafter referred to as the Bayesian Threat Probability Module. The output of this module, combined with the impact of assets, provides a quantitative and dynamic risk output.

The novelty of the proposed approach lies in its ability to generate a dynamic threat (probability) value by collecting and combining relevant information from multiple open sources and integrating them into the Bayesian Threat Probability Module. Specifically, to the best of the authors' knowledge, this is the first attempt to integrate EPSS values into a DRA methodology. Given that EPSS provides a probability of exploitation within the next 30 days, this framework can be characterized as both dynamic and proactive.

Additionally, this approach makes a significant effort to convert qualitative CAPEC values into quantitative data. These values are then combined with EPSS scores using a method to create a threat score. This score reflects the probability of exploitation of a vulnerability, as a prerequisite for attack success. Finally, our Bayesian Threat Probability Module integrates these threat scores with values representing the likelihood of the target being attacked by an APT group. This integration accounts for information such as the location and industry sector of the target, comparing it with similar data on APT groups. Our approach considers the potential changes in threat scores due to the involvement of APT groups.

The rest of the paper is organized as follows: Section 2 presents background information relevant to this study, while Section 3 reviews related work. Section 4 details the proposed methodology, followed by a detailed application of this methodology within an artificial SCADA environment in Section 5. Section 6 offers remarks on the outcomes of the application of our methodology, and analyzes the impact of security mechanisms on risk reduction. Section 7 highlights the study's findings, compares them with related research, and discusses the limitations of the proposed model. Section 8 outlines potential directions for future work, while Section 9 provides a comprehensive conclusion of the study.

2. Background

The CVE initiative is responsible for the identification, definition, and public disclosure of vulnerabilities specifically related to cybersecurity. Each cybersecurity vulnerability is assigned a unique record within the CVE catalog, known as a CVE-ID. This identifier follows the format CVE-year-arbitrary digits; for example, CVE-2019-11510 represents a vulnerability discovered in 2019.

The EPSS model aggregates vulnerability-related information from multiple sources to produce quantitative evaluations regarding the probability of exploitation of vulnerabilities within the next 30 days. EPSS employs machine learning techniques to identify patterns and correlate vulnerability information with relevant exploitation activity. The result of this process is an exploitation probability score assigned to each CVE, based on various factors such age of vulnerability, publicly available exploit code and other relevant considerations. Regarding the utilization of EPSS within the risk calculation Eq. (1),

$$Risk = Threat \times Vulnerability \times Impact \tag{1}$$

The authors of the EPSS model clearly state that EPSS scores should be applied within the threat component, rather than the vulnerability component.

Common Weakness Enumeration (CWE) is a comprehensive list of common software and hardware weaknesses that are identified and developed by the cybersecurity community. A weakness refers to a condition in hardware, firmware, or software that may contribute to the creation of vulnerabilities under certain circumstances. Each CWE is uniquely identified by a CWE-ID, which serves to specify and track individual weaknesses. The National Vulnerability Database (NVD) (Anon, 2024e) allows users to link specific CVE-IDs to corresponding CWE-IDs, enabling the identification of underlying weaknesses associated with particular vulnerabilities. It is common for multiple CVE-IDs to be associated with a single CWE, as a single type of weakness can lead to multiple distinct vulnerabilities. In this study, we utilize the NVD website to correlate CVEs with CWEs, though the MITRE CWE website offers a similar capability.

The Common Attack Pattern Enumeration and Classification (CAPEC) initiative provides a comprehensive catalog of common attack patterns that adversaries might utilize, helping users understand how weaknesses in systems can be exploited. CAPEC offers detailed descriptions of the potential techniques employed by adversaries to effectively exploit these weaknesses. Additionally, it outlines the challenges that adversaries may encounter in their efforts to exploit such vulnerabilities.

The CAPEC catalog follows a structured hierarchy. At the top are Category attack patterns (C), which encompass broad groups of attacks that share common characteristics. Below these are Meta attack patterns (M), which provide abstract characterizations of specific techniques found within Category attack patterns. Further down, Standard attack patterns (S) focus on specific techniques employed in attacks. Below Standard attack patterns are Detailed attack patterns (D), which offer in-depth descriptions of specific attack patterns, illustrating the complete flow of an attack. Each type of CAPEC entry (Category, Meta, Standard, Detailed) is assigned a unique identifier. Meta, Detailed, and Standard CAPECs often include a field labeled "Likelihood of Attack", which is a qualitative measure indicating the probability of a successful attack. This likelihood is typically categorized as *low*, *medium*, or *high*, reflecting the probability of an attack's success based on various factors, such as the prerequisites for a successful attack or the skill level required of the attacker and other relevant considerations (Anon, 2024a).

The MITRE ATT&CK framework provides publicly accessible information about how adversaries utilize tactics and techniques, based on real-world examples. This framework details the interactions of adversaries with systems, reflecting various phases within an attack lifecycle. It also follows a structured approach, with Tactics at the top level representing the objectives behind an adversary's actions. These are followed by Techniques, which describe how adversaries achieve their goals. Each Tactic is assigned a unique ID starting with "TA", while each Technique has a unique ID beginning with "T". A single Tactic encompasses multiple Techniques and Subtechniques.

Techniques and Subtechniques offer detailed information about procedures, which are the specific actions implemented by adversaries. Within the Procedures, there are references to specific APT Groups that use the technique. Furthermore, the MITRE ATT&CK framework provides descriptions of each APT Group, including details about their targets, origins, and operations.

3. Related work

Cam (2015) presented a model for dynamically and quantitatively assessing network risks. The model utilizes a vulnerability scanner to detect system vulnerabilities, followed by a Bayesian network to capture relationships between them. The authors expand the Common Vulnerability Scoring System (CVSS) model by incorporating asset mission criticality, current damage, and the impact of vulnerabilities on other assets. They also employ a hidden Markov model along with Bayesian networks to dynamically assess exploit likelihood based on cyber operations, events, and observations from Intrusion Detection Systems (IDS), firewalls, etc. Risk is estimated by identifying the most likely exploitation paths and their impacts.

Henshel et al. (2016) proposed a quantitative DRA approach that models both system components (software, hardware, network) and human factors. The approach relies on expert judgment for the initial assessment of the system's risk variables. Using Bayesian networks, they assessed cyber risks and represented the connections between nodes. This approach accounts for dependencies between assets and their interactions with events to quantify vulnerabilities, attack impacts, and risks.

Zhang et al. (2016) recommended a multilevel Bayesian network to model the propagation of cyber risk, comprising an incident model, a function model, and an attack model. Their approach assesses cybersecurity risk in ICS by estimating probabilities and quantifying the consequences of potential attack scenarios, integrating both offline data (from vulnerability scanners, statistical analysis, and expert opinions) and online data from IDS and anomaly detection system.

A DRA quantitative model was presented by Huang et al. (2017) to assess cyber risk in SCADA environments. The model incorporates vulnerability nodes (associated with CVEs) and privilege escalation nodes (representing points that can be exploited to damage the system), along with the network topology, into a Bayesian network. This approach calculates posterior threat probabilities using data collected from IDS.

Peng et al. (2018a) introduced a DRA methodology capable of quantitatively assessing cyber risk in ICS environments using Bayesian networks. The model constructs the Bayesian network using system security knowledge, such as vulnerabilities, functions, and assets, and integrates this with attack evidence to calculate the posterior probability of an event's occurrence. This probability is then combined with the impact associated with each asset to determine the risk.

Zhu et al. (2018) proposed a model for quantitatively assessing risk in Industrial Production Systems by calculating the probabilities and consequences of abnormal events. The model integrates two key components: probability inference and loss calculation, which are combined to produce real-time risk assessments. An extended multilevel flow process is used to describe the production process, allowing the model to forecast the consequences of abnormal events quantitatively. For probability inference, a Bayesian network is used to estimate the likelihood of such events. The model's inputs include established control strategies and attack evidence from the IDS.

Zhang et al. (2018) introduced a DRA model for quantitatively assessing cybersecurity risk in ICS, utilizing fuzzy probability Bayesian networks. The model integrates system security knowledge with information from anomaly evidence and IDS data to calculate posterior threat probabilities. Risk is then determined using the Bayesian network's output in conjunction with asset losses.

Zhou et al. (2023) presented DRA model for quantitatively assessing cybersecurity risk in distributed Cyber–Physical Systems (CPS). The model constructs a Bayesian network based on the system's network topology, detected CVSS scores, and available defense resources. The authors utilized GeNIe to simulate and evaluate the model's effectiveness across three different attack scenarios.

Dimitriadis et al. (2020) proposed a method for risk assessment in smart sensor environments by combining business process management (business logic) with security standards and frameworks. The model integrates the CVE-CWE-CAPEC pathway to identify the potential likelihood of attacks' success, based on detected CVEs. These likelihoods are then combined with the impact on the Confidentiality, Integrity, and Availability (C-I-A) attributes to calculate risk qualitatively.

Lyu et al. (2020) proposed a DRA methodology to quantitatively estimate risk in Cyber–Physical Systems (CPS). The model utilizes vulnerability nodes (CVEs) and machine nodes, which represent the systems an attacker gains access to after successfully exploiting vulnerabilities. They use the exploitability equation from the CVSS to calculate the initial probabilities of vulnerabilities being exploited. Additionally, they employ logic gates, as proposed by Poolsappasit et al. (2012), to construct Conditional Probability Tables (CPTs). The model incorporates these data, along with the network topology of the environment, in order to estimate posterior probabilities. These probabilities are then combined with impact assessments to calculate risk. The authors utilized GeNIe to simulate and evaluate the model's accuracy.

While our proposed methodology shares similarities with the works of Peng and Huang, it is most closely aligned with the approach presented by Lyu, since our methodology utilizes the same logic regarding the nodes used for constructing the Bayesian network structure and also employs logic gates to create the CPTs. Additionally, both the works by Zhu and Lyu utilize the GeNIe software (Anon, 2024d) for the construction of Bayesian networks, as does our approach. The work by Dimitriadis aligns with our approach by utilizing the CVE-CWE-CAPEC pathway to detect and incorporate CAPEC's attack likelihood values. However, our methodology introduces several noteworthy distinctions:

- We incorporate the EPSS scores, which aggregate data from multiple cybersecurity sources to estimate the likelihood of exploitation of a vulnerability within the next 30 days. This proactive approach enhances our model by providing a forward-looking threat probability.
- Our model identifies and integrates potential APT groups that may target the environment based on detected vulnerabilities and specific information related to the target. This process is used to examine the influence of APTs on risk estimation
- We convert CAPEC's qualitative attack likelihood values into quantitative data, which we then combine with EPSS values using a probabilistic method. This creates a more comprehensive initial threat score that incorporates diverse cybersecurity information.
- We offer insights into the effect of security mechanisms on risk reduction by including a scenario that assumes the installation of a firewall, demonstrating its impact on reducing risk.

The proposed approach, as elaborated upon in the forthcoming section, not only aligns with existing methodologies but also introduces innovative elements that enhance its applicability and effectiveness in cybersecurity risk assessment.

4. Proposed methodology

Our methodology begins by detecting all relevant vulnerabilities (CVEs) in the target environment (Fig. 1). The model then uses these CVEs to determine their corresponding EPSS scores and identify associated CWEs, CAPECs, and MITRE ATT&CK techniques. This process is repeated for each asset within the target environment.

From the aforementioned process, our methodology analyzes the identified CAPECs and stores the one with the highest likelihood of

attack value for future use. Based on the detected CAPECs, it also finds the corresponding technique IDs from the MITRE ATT&CK framework for the relevant assets. Upon identifying these techniques, the model examines all APT Groups associated with this technique. By analyzing the descriptions of these APT groups, we extract information about their geographic location and industry of interest, which are compared with relevant information about the target environment.

In the next step, CAPECs and the associated APT Groups are converted into numerical values. The converted CAPEC scores, along with the EPSS scores, are combined using a probabilistic method. In the final step, this combined score, along with the numerical values of APT Groups (APT Groups Indicators) and information related to attackers' movements based on network topology, serves as input to the Bayesian Threat Probability Module. The model utilizes the output of this module, which provides the posterior threat (probability) score for each asset, in combination with the impact values to deliver quantitative and dynamic risk estimations for each asset.

4.1. Information collection — Step 1

The initial phase of our methodology focuses on collecting all information necessary for dynamic risk assessment from relevant sources. The external data collection process begins with the identification of Common Vulnerabilities and Exposures (CVEs) associated with each asset within the target environment. CVE identification can be conducted either through a vulnerability scanner, such as Nessus (Anon, 2024f), or by leveraging the National Vulnerability Database (NVD) API in combination with the Common Platform Enumeration (CPE) identifiers of the assets present in the target environment.

Once the CVEs have been detected, we employ them in two distinct tasks. The first task involves using the detected CVEs to obtain the corresponding EPSS scores, which are utilized to determine the probability of exploitation for each asset where CVEs were detected. In the second task, we follow a sequential process to identify related CWEs, which are then used to detect associated CAPECs and retrieve their likelihood of attack. It is important to note that a single CVE may correspond to multiple CWEs. In such instances, we extract and examine each of the identified CWEs. Subsequently, the detected CWEs are utilized to locate the corresponding CAPECs. Often, one CWE can correspond to multiple CAPECs. In these cases, our model selects and utilizes the CAPEC with the highest likelihood of attack value (Dimitriadis et al., 2020), as the worst-case scenario poses the greatest threat to an asset.

In addition, we examine which assets within the target network topology are exposed to potential attackers. In other words, our model assesses the attackers' perspective on how they could penetrate the network. For these assets, referred to as "bridge" assets in our model because they serve as potential entry points for attackers, the model identifies relevant MITRE ATK&CK techniques using the previously detected CAPECs (Hemberg et al., 2020). Since CAPECs are linked to CVEs through CWEs, this process effectively matches CVEs to MITRE ATT&CK techniques (Kuppa et al., 2021). It then detects all the APT Groups associated with the specific technique ID from the MITRE ATT&CK website.

Finally, we analyze the descriptions of APT Groups at MITRE ATT&CK website to find information regarding their areas or locations and industries of interest. Based on these descriptions and relevant information about the target (such as its geographic location and industry), we retain only those APT groups that may have an interest in this specific target.

The rationale behind the selection of data sources in this study is based on their relevance to cybersecurity and their ability to provide the necessary information for our model. Specifically, EPSS serves as a critical data source in our model, as it enhances its proactive capabilities. EPSS scores are inherently forward-looking, providing probabilistic estimates of vulnerability exploitation within the next 30 days. In our methodology, these scores are integrated into the Bayesian network as part of the updated threat calculation. Additionally, our methodology defines risk as the product of *threat* × *impact*, where the threat vector is derived from the Bayesian network's output. Since EPSS scores are proactive, the resulting risk assessments are also forward-looking, providing risk estimations for the upcoming 30-day period.

The CAPEC framework was selected due to its ability to provide insights into the likelihood of attack, which, when correlated with identified vulnerabilities through the CVE-CWE-CAPEC pathway, enhances threat modeling. Finally, the MITRE ATK&CK framework was incorporated as it provides information that can be quantified by our model to examine the influence of APT groups within cyber risk assessment.

Table 1
Quantification of CAPEC likelihood.

CAPEC original likelihood	Numerical value
Low	0.2
Medium	0.5
High	0.8

4.2. Probabilistic method and data quantification — Step 2

The second phase of our methodology focuses on transforming the qualitative data obtained in Step 1, specifically the CAPEC likelihood, into a quantitative format and integrating it with the quantitative data collected in Step 1, namely the EPSS. This integration aims to generate a unified threat score that is suitable for incorporation into the Bayesian Threat Probability Module. Additionally, this step converts data related to APT Groups into a numerical format to facilitate its integration into the Bayesian Threat Probability Module.

To integrate both EPSS and CAPEC scores into a unified and coherent threat score, we employ a probabilistic method grounded in the definitions provided by EPSS and CAPEC. Specifically, EPSS offers a score reflecting the probability of vulnerability exploitation, while CAPEC which can be linked with vulnerabilities through CWE, provides information regarding the likelihood of a successful attack.

We assume that for an attack to succeed, vulnerability exploitation must occur as an initial step. In this context, let event A represent the exploitation of a vulnerability and event B represent the success of the attack, which follows event A. Based on this relationship, the overall probability, representing the threat score, can be calculated as follows:

$$P = P(A) * P(B/A) \tag{2}$$

Here, P(A) is directly derived from the EPSS score, while P(B/A) is inferred from CAPEC's qualitative categories related to the likelihood of a successful attack. To calculate the overall probability, or threat score, CAPEC's qualitative values must first be converted into a numerical format. CAPEC provides three qualitative values as the outcome of its estimation of the likelihood of attack success: *low*, *medium*, and *high*. To convert the qualitative likelihood categories used in CAPEC (low, medium, high) into a numerical format, the corresponding values were selected, as shown in Table 1.

The selection of numerical values within the 0–1 range facilitates the integration of CAPEC's likelihood assessments into our probabilistic method. The output of this method serves as the primary input for our Bayesian Threat Probability Module. Additionally, the selected values are proportionally distributed across the 0 to 1 range to reflect varying degrees of likelihood, ensuring that no particular category is disproportionately emphasized. A *low* likelihood is represented by 0.2, indicating a relatively low, yet non-zero, probability of occurrence. A *medium* likelihood is assigned a value of 0.5, signifying an equal probability of occurrence and non-occurrence. A *high* likelihood is represented by 0.8, denoting a strong probability of occurrence, while still accounting for residual uncertainty. Finally, the conversion of qualitative values into

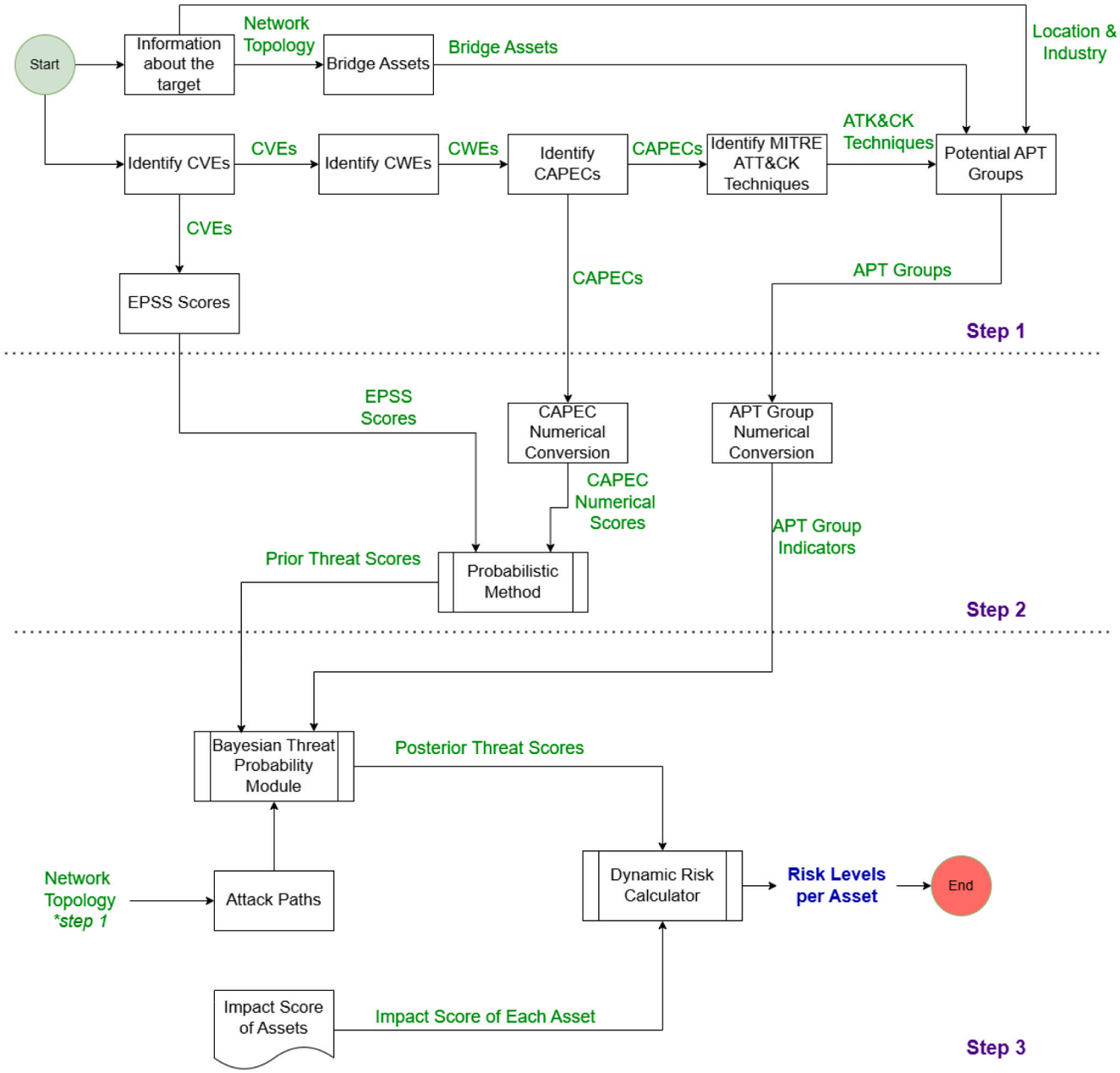

Fig. 1. Proposed methodology flowchart.

numerical representations within the 0–1 range is an established practice in risk management, particularly when quantitative risk analysis is required (Freund and Jones, 2014).

In the final step of this process, our methodology converts the detected APT Groups into numerical values, termed APT Groups Indicators, for integration into our Bayesian Threat Probability Module. This is achieved by evaluating the total number of APT Groups relevant to the target environment, based on the following criteria:

1. The geographic location of the organization compared to regions where the APT Groups have previously conducted attacks.
2. The comparison between the industry in which the organization operates and the industries targeted or of interest to the APT Groups.

When an APT Group matches both criteria (geographic location and industry), a value of 0.1 is assigned. This process is then repeated for each detected APT Group, and the sum of these values is used to generate the APT Group Indicator.

The maximum value an APT Group Indicator can have per asset is 1, which corresponds to a maximum of 10 APT Groups. Even in cases where more than 10 APT Groups are related to the target environment, we assume that the threat level remains consistent, and thus, we assign the maximum value of 1. This approach ensures that the APT Groups Indicators are effectively integrated into our Bayesian Threat Probability Module. This simplified approach compensates for the lack of advanced Cyber Threat Intelligence (CTI) which could provide useful information regarding the attractiveness of an asset to specific threat groups. Although this is a potential area for future work, in a real deployment, these values can be adjusted by the security analyst as needed.

4.3. Bayesian threat probability module — Step 3

The final phase of our methodology involves constructing a Bayesian network to estimate posterior threat scores for each asset. These scores are then integrated into a risk formula alongside the impact of each asset to enable dynamic and proactive risk assessments.

The rationale for choosing Bayesian networks lies in their ability to model probabilistic dependencies and dynamically update threat probabilities, thereby enhancing risk estimations. Bayesian networks have been widely adopted in dynamic risk assessment within the field of cybersecurity (Cheimonidis and Rantos, 2023) due to their capacity to integrate multiple risk factors and model attack propagation based on network topology. In our methodology, Bayesian networks facilitate the integration of diverse threat-related information along with attack paths to dynamically estimate threat probabilities and corresponding risk levels. Their probabilistic inference capability ensures that the risk assessment model remains dynamic and refines risk estimations as new vulnerabilities emerge.

A Bayesian network is a probabilistic model that uses Directed Acyclic Graphs (DAGs) to connect dependent variables (Jensen and Nielsen, 2007). The joint probability of each variable within the model can be obtained through a set of local conditional distributions with respect to their parent nodes (Johnson et al., 2018). A Bayesian network can be expressed as $N = \{G, P\}$ (Peng et al., 2018b), where:

- $G = \{V, E\}$ denotes the structure of a DAG in which V are nodes and E are directed edges.
- P represents the parameters associated with the probability distributions of V, typically expressed in the form of a Conditional Probability Tables.

To utilize a Bayesian Network within our model, the structure of the network must first be defined. In our case, we employ 3 different types of nodes:

1. (T): Represents the *threat nodes*, indicating threats that may harm the system, by exploiting the identified CVEs detected in the assets.
2. (APT): Represents the *APT nodes*, signifying APT Groups that may show interest in attacking the specific target.
3. (A): Represents the *asset nodes*, denoting assets that attackers may gain access utilizing the threats connected to these assets.

To construct a Bayesian network that accurately represents the target environment, it is essential to consider the unique network topology and the potential movements of attackers within this topology. Once this is established, we can construct our Bayesian network with T, APT and A nodes. After successfully constructing the Bayesian network, we need to determine the CPT parameters for each T, APT and A nodes.

Expert judgment can also be used to create the CPT tables, but this approach may be poor or subjective (Mkrtchyan et al., 2016). To avoid this and ensure objectivity, we utilize the values provided by step two, which are the outcomes of the EPSS model and CAPEC framework to populate the CPTs on threat nodes. These two open-resources are publicly accepted in the field of cybersecurity, and serve as primary data sources related to threat nodes. Asset nodes are determined by the network topology and the potential movements of attackers, in combination with threat nodes and APT nodes. Finally, we integrate APT Groups Indicators exclusively for nodes considered as "bridge" nodes by our model.

In addition, our model utilizes the logic gates proposed by Poolsappasit (Poolsappasit et al., 2012) to obtain the conditional probability distribution of each node in the Bayesian network. This logic employs two types of gates: "AND" and "OR" to address cybersecurity related events. The AND gate is used when all cybersecurity events must be triggered for a cybersecurity incident to occur. Conversely, the OR gate is used when only one cybersecurity event needs to be triggered for a cybersecurity incident to occur. In our methodology, we employ the OR gate when an asset node can be compromised by multiple threats, any of which can cause harm. The conditional probability can be calculated using Eq. (3):

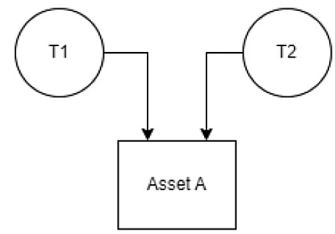

Fig. 2. Use of OR gate.

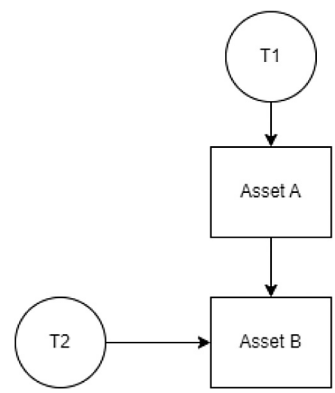

Fig. 3. Use of AND gate.

$$Pd = 1 - \prod_{i=1}^{n} \left(1 - P_{(i)}\right) \tag{3}$$

The use of the OR gate is illustrated in Fig. 2, where T1 and T2 are two threats that may cause harm to "Asset A".

On the other hand, our model uses the AND gate when both a threat (threat node) and the successful compromise of a previous asset (parent asset node) must be triggered to gain access to the next node. The conditional probability can be calculated using Eq. (4):

$$Pc = \prod_{i=1}^{n} P(i) \tag{4}$$

The use of the AND gate is illustrated in Fig. 3, where T1 represents the threat to 'Asset A' and T2 represents the threat to 'Asset B'. In this scenario, for an attacker to gain access to 'Asset B', they must utilize T2 and have already gained access to 'Asset A' (T2 AND 'Asset A').

The introduction of these two logic gates is instrumental in constructing the CPTs for each node within the network. Additionally, the adopted logic closely mirrors real-world attack scenarios, representing potential attack paths an attacker may follow based on the specific network topology of each target environment. The construction of the Bayesian network and the corresponding CPTs enables our Bayesian Threat Probability Model to dynamically update the threat probability associated with each asset. This capability facilitates the application of the widely accepted definition of risk provided by Kaplan and Garrick (1981) in Eq. (5):

$$Risk = \sum_{i} P(A_i) \times S(A_i) \tag{5}$$

where $P(A_i)$ is the posterior probability (i.e., the output of our Bayesian Threat Probability Module) and $S(A_i)$ is the impact of each asset.

The impact scale used in this study is designed to reflect the functionality of each asset within the organization's environment. It has been selected purely for demonstration purposes and does not pertain

Table 2
Impact scale.

Description	Impact score
Insignificant impact on asset functionality. All services are operational.	0
Limited impact on asset functionality. Most services remain operational.	1
Moderate impact on asset functionality. Some services are operational.	2
Severe impact on asset functionality. No services are operational.	3

to the Confidentiality, Integrity, or Availability (CIA) attributes of an asset, nor does it involve any monetary valuations. Table 2 presents a description of each impact level along with its corresponding impact score. This impact score is intended solely to measure the degradation of asset functionality within this specific context.

However, risk analysts and cybersecurity teams can integrate their own impact assessment scales into this model to generate comprehensive risk estimations. By doing so, they can incorporate broader considerations, such as CIA attributes, or financial metrics, to align with their specific risk management framework.

To demonstrate the application of our proposed methodology, the following Section presents a simulated attack scenario within an artificial SCADA environment.

5. Case study

In this study, we present a simulated attack scenario targeting a Supervisory Control and Data Acquisition (SCADA) environment. SCADA systems are Industrial Control Systems used for real-time monitoring and management of critical infrastructure, including power grids, water treatment plants, and manufacturing facilities. These systems enable remote operation and automation but are increasingly targeted by cyber threats due to their integration with modern communication networks (Yadav and Paul, 2021).

For demonstration purposes, we assume that the target facility is an electric power station located in Western Europe. The SCADA network comprises various interconnected devices, including Workstations (WS), a Historical Database (HDB), a Human–Machine Interface (HMI), and Programmable Logic Controllers (PLCs) (Chandia et al., 2008). A typical SCADA network consists of three foundational layers: the enterprise network layer, the industrial network layer, and the field or physical network layer (Wang et al., 2010), which we adopt in this scenario.

The target network topology includes the enterprise network layer, which comprises key components such as a Virtual Private Network (VPN) for remote access and a Workstation (WS) that serves as the primary interface for administrative tasks. Additionally, this layer includes a Web Server (WebS), which hosts the facility's website. The enterprise network layer is responsible for integrating the SCADA system with business logic, ensuring secure remote access and administrative control.

The industrial network layer, which serves as the central hub for managing industrial operations, comprises several critical components, including the Historical Database (HDB), responsible for storing and logging SCADA-related data, and the Human–Machine Interface (HMI), which facilitates the monitoring and supervision of Programmable Logic Controllers (PLCs). Assets within the industrial network layer communicate with the WS in the enterprise network layer to ensure seamless data flow and operational coordination.

At the lowest level, the field network layer consists solely of the PLC, which directly interfaces with physical devices such as actuators and sensors. The PLC communicates with components of the industrial network layer to facilitate data exchange, real-time monitoring, and process control. The network topology utilized for this study is presented in Fig. 4.

Although the scenario employed for demonstrative purposes is fictitious, it endeavors to portray a realistic environment. For this reason, the vulnerabilities chosen for this case study represent real CVEs that

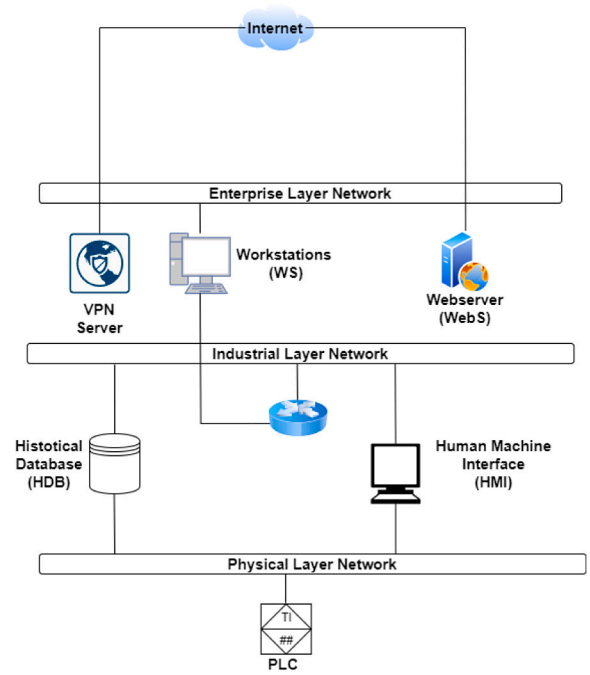

Fig. 4. Experimental environment.

have been detected in such assets. In our scenario, the VPN is susceptible to CVE-2019-11510, allowing an unauthenticated remote attacker to exploit a specially crafted URI, thereby facilitating unauthorized file reading that could be used for authentication. The Web Server is vulnerable to a Cross-site scripting vulnerability (CVE-2007- 6388), allowing remote attackers to inject arbitrary scripts. Additionally, the WorkStation has vulnerabilities CVE-2017-0143 and CVE-2017-8692, both of which provide opportunities for remote code execution. In the context of the industrial layer, the HMI bears three vulnerabilities: CVE-2011-4875, which allows remote attackers to execute arbitrary code; CVE-2011-4867, which allows remote attackers to execute, read, create, modify, or delete arbitrary files; and CVE-2011-4877, which allows remote attackers to cause denial-of-service. The other asset in the industrial layer, the HDB, is vulnerable to CVE-2017-8917, which allows attackers to execute arbitrary SQL commands. At the field layer, the PLC has one vulnerability, CVE-2017-7515, which allows remote attackers to discover the application-protected password and subsequently use it for malicious modifications.

The exploitation of these vulnerabilities could have severe consequences, including unauthorized access to SCADA systems, operational disruptions, data integrity breaches, and even physical damage due to manipulated industrial processes. The sum of CVEs utilized for this case study is presented at Table 3.

The first step in our methodology involves collecting all the necessary data required for the proper functioning of our model. As previously described, there are two distinct processes for collecting the relevant information, also shown in Fig. 1. The first process entails using detected CVEs to retrieve corresponding EPSS scores. This can be accomplished either through the EPSS API or by using the Comma

Table 3
Vulnerabilities.

No	Layer	Host	CVE
1	Enterprise	VPN	CVE-2019-11510
2	Enterprise	Web Server	CVE-2007-6388
3	Enterprise	WorkStation	CVE-2017-0143
4	Enterprise	WorkStation	CVE-2017-8692
5	Industrial	HMI	CVE-2011-4875
6	Industrial	HMI	CVE-2011-4876
7	Industrial	HMI	CVE-2011-4877
8	Industrial	HDB	CVE-2017-8917
9	Field	PLC	CVE-2017-7515

Table 4
Vulnerabilities and EPSS scores.

No	Layer	Host	CVE	EPSS score
1	Enterprise	VPN	CVE-2019–11510	0.974
2	Enterprise	Web Server	CVE-2007–6388	0.843
3	Enterprise	WorkStation	CVE-2017–0143	0.960
4	Enterprise	WorkStation	CVE-2017–8692	0.163
5	Industrial	HMI	CVE-2011–4875	0.307
6	Industrial	HMI	CVE-2011–4876	0.032
7	Industrial	HMI	CVE-2011–4877	0.045
8	Industrial	HDB	CVE-2017–8917	0.976
9	Field	PLC	CVE-2017–7515	0.114

Separated Value (CSV) file provided on the EPSS website. Table 4 presents the assets, layers, CVEs, and their EPSS scores.

The second process in this step involves collecting all relevant CAPECs for the detected CVEs. To achieve this, it is necessary to first identify the CWEs for each detected CVE and then use the CWEs to locate the corresponding CAPECs. By following this process, we can match each CVE to one or more CAPECs. Table 5 presents all the CVEs along with their associated CWEs and CAPECs.

Having identified the CAPECs that correspond to the detected CVEs, we need to examine the attack likelihood for each CAPEC. As previously clarified, we consider only the worst-case scenario for potential threats. Consequently, our focus is on identifying the CAPEC with the highest attack likelihood from the set of CAPECs associated with each CVE. This approach ensures that we prioritize and address the most critical security threats. Since multiple CAPECs can correspond to a single CWE, it is necessary to examine each CAPEC in sequential order as provided by the CWE listings. For example, for CWE-22, the first CAPEC to be considered is CAPEC-126. After sequentially examining each CAPEC, we need to identify the one with the highest attack likelihood, which is marked as *high*. Table 6 presents all assets within our scenario, along with their associated CVEs, CAPECs, and the likelihood of attack for each CAPEC (indicated by their IDs).

Next, our methodology examines the "bridge" assets, which are potential targets for attackers and could serve as entry points to the target network. In our scenario, there are two "bridge" assets: the VPN and the Web Server, both of which are accessible via the Internet. For these assets, we need to investigate if there are any Techniques IDs from the MITRE ATT&CK framework associated with the CVEs detected on them. Having already identified the CAPECs related to these CVEs, we need to examine these CAPECs to find any associated Techniques IDs. This requires analyzing not only the detected CAPECs but also the relationships between these CAPECs and their parent CAPECs, as detailed attack patterns often connect to MITRE ATT&CK Techniques through their parent CAPECs (*standard level* attack pattern).

In our scenario, the VPN is vulnerable to CVE-2019-11510, which is linked to five different CAPECs (126, 64, 76, 78, 79) via CWE-22. By examining these CAPECs, we can observe that CAPECs 64, 76, 78, and 79 (*detailed level* attack patterns) are children of CAPEC 267 (standard attack pattern), which matches the Technique ID:T1027 from the MITRE ATT&CK framework. CAPEC 126 is a standard attack pattern with no match to the MITRE ATT&CK framework.

The other "bridge" asset in our methodology is the Web Server (WebS), which is vulnerable to CVE-2020-6388, linked to six CAPECs (209, 588, 591, 592, 63, 85) through CWE-79. CAPECs 209, 588, 591, and 592 are detailed attack patterns, and their parent is CAPEC 63, a standard attack pattern with no match to the MITRE ATT&CK framework. On the other hand, CAPEC 85, also a detailed attack pattern, has parent CAPEC 580, a standard attack pattern. By examining this CAPEC, we find a match with Technique ID: T1082 from the MITRE ATT&CK framework. Table 7 presents the "bridge" assets, along with their CVEs, the detailed CAPECs (children), and the standard CAPECs (parents). The latter match with techniques from the MITRE ATT&CK framework.

The identification of relevant MITRE ATT&CK Techniques is the final process of this step in our methodology. The goal of this step is to collect all necessary information, including EPSS scores, CAPECs, and MITRE ATT&CK Techniques, to be used in the following steps.

5.1. Methodology Step 2 — Probabilistic method and data quantification

In order for our Bayesian Threat Probability Module to function, we need to convert all qualitative data (CAPEC, MITRE ATT&CK Techniques) into quantitative format and combine them with the other quantitative data (EPSS). As described in Section 4.2, we use a probabilistic method to combine EPSS and CAPEC. Before applying the probabilistic method (2), we need to convert CAPEC qualitative values into quantitative values using the relative scoring presented in Table 1. Table 8 presents all assets utilized for this scenario, along with their CVEs, CAPECs' qualitative attack likelihood, and its numerical conversion.

Moving forward, we need to combine the EPSS score of each CVE with the outcome of the above process using Eq. (2). This equation

Table 5
Vulnerabilities, CWEs and CAPECs.

Asset	CVE	CWE	CAPEC
VPN	2019–11510	22	126, 64, 76, 78, 79
WebS	2007–6388	79	209, 588, 591, 592, 63, 85
WS	2017–0143	20	10, 101, 104, 108, 109, 110, 120, 13, 135, 136, 14, 153, 182, 209, 22, 23, 230, 231, 24, 250, 261, 267, 28, 3, 31, 42, 43, 45, 46, 47, 473, 52, 53, 588, 63, 64, 664, 67, 7, 71, 72, 73, 78, 79, 8, 81, 83, 85, 88, 9
WS	2017–8692	119	10, 100, 123, 14, 24, 42, 44, 45, 46, 47, 8, 9
HMI	2011–4875	119	10, 100, 123, 14, 24, 42, 44, 45, 46, 47, 8, 9
HMI	2011–4876	22	126, 64, 76, 78, 79
HMI	2011–4877	20	10, 101, 104, 108, 109, 110, 120, 13, 135, 136, 14, 153, 182, 209, 22, 23, 230, 231, 24, 250, 261, 267, 28, 3, 31, 42, 43, 45, 46, 47, 473, 52, 53, 588, 63, 64, 664, 67, 7, 71, 72, 73, 78, 79, 8, 81, 83, 85, 88, 9
HDB	2017–8917	89	108, 109, 110, 470, 66, 7
PLC	2017–7575	200	116, 13, 169, 22, 224, 285, 287, 290, 291, 292, 293, 294, 295, 296, 297, 298, 299, 300, 301, 302, 303, 304, 305, 306, 307, 308, 309, 310, 312, 313, 317, 318, 319, 320, 321, 322, 323, 324, 425, 326, 327, 328, 329, 330, 472, 497, 508, 573, 574, 575, 576, 577, 59, 60, 616, 643, 646, 651, 79

Table 6
Assets, CVEs, CAPECs, and likelihood of attack.

Asset	CVE	CAPEC-ID	Likelihood of attack
VPN	2019–11510	126	high
WebS	2007–6388	588	high
WS	2017–0143	10	high
WS	2017–8692	10	high
HMI	2011–4875	10	high
HMI	2011–4876	126	high
HMI	2011–4877	10	high
HDB	2017–8917	110	high
PLC	2017–7575	116	high

multiplies the original EPSS score with CAPEC's attack likelihood which is 0.8 for all assets. Table 9 analytically presents the outcome of this process. The value generated by this process will be used in the Bayesian Threat Probability Module. This value represents the combined probability of vulnerability exploitation (EPSS) as a prerequisite for a successful attack (CAPEC).

The final process of this step of our methodology involves converting the detected APT Groups associated with the identified "bridge" assets and their relative CVEs, into numerical values, referred to as APT Groups Indicators, for use in our Bayesian Threat Probability Module. To accomplish this, we first need to determine the total number of APT Groups associated with each detected technique. For example, the VPN, which matches with Technique ID T1027, has 15 associated APT Groups, while the WebS which matches with Technique ID T1082 has 46 associated APT Groups.

Next, we examine the description of each detected APT Group with information relevant to the target environment. In this scenario, we assume the target is a government electric facility located in Western Europe. We examine the area of interest and industry of interest for each of the 61 detected APT Groups to identify which ones may potentially target this facility. We create two criteria (area of interest and industry of interest) and identify APT Groups that meet both criteria. For TD T1027, 3 out of 15 APT Groups meet the criteria, resulting in an APT Groups Indicator score of 0.3. For TD T1082, 9 out of 46 APT Groups meet the criteria, resulting in a score of 0.9.

For demonstration purposes, we present some APT Groups related to Technique T1027 from MITRE ATT&CK framework and their relevance to the criteria chosen in Table 10. For example, Earth Lusca is an APT Group that has targeted countries in Western Europe (Germany, France) and government facilities, making our facility a potential target (2/2 criteria). Conversely, BlackOasis has not targeted either Western Europe or government facilities (0/2 criteria). Lastly, although BackdoorDiplomacy has conducted attacks in Europe, they have not targeted government facilities, thus fulfilling only one of the two criteria. In this small example, the score for the APT Group indicator will be 0.1.

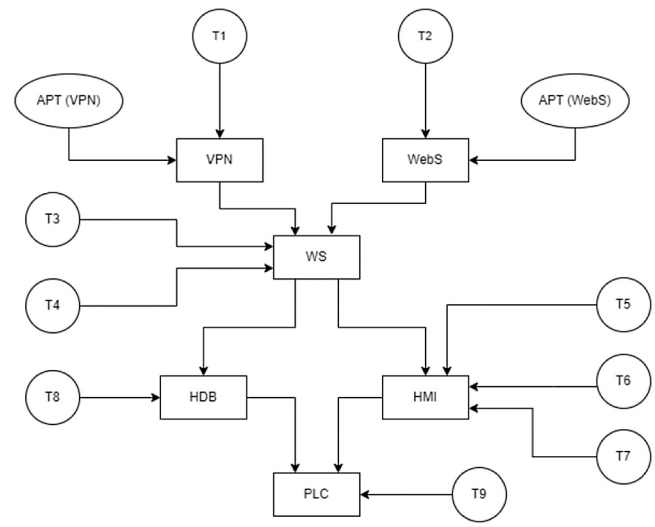

Fig. 5. Bayesian network structure.

Lastly we present all relevant information which will be utilized by our Bayesian Threat Probability Module as the outcome of this step at Table 11.

5.2. Methodology Step 3 — Bayesian threat probability module

In the final step of our methodology, we begin by defining the structure of the Bayesian network. As detailed in Section 4.3, the network is composed of three types of nodes: *threat nodes*, *APT nodes*, and *asset nodes*. Considering the unique network topology of the target environment and potential attackers' movements in relation to these node types, we construct the Bayesian network, as illustrated in Fig. 5.

The threat nodes, which are associated with the detected CVEs, are depicted as circular shapes, each labeled with its corresponding Threat name (T1,T2 etc.). These nodes represent the threat score of each node as it was estimated by the second step of our methodology, noting that there are instances where a single asset (e.g., WS) is connected with multiple threats. The asset nodes are represented as rectangular shapes, labeled with the asset's name (e.g., HMI). Additionally, we include APT Groups Indicator nodes, represented as ellipses, each associated with a description of the asset that the APT Groups Indicator pertains to. In our model, threat nodes and APT Groups Indicator nodes are treated equivalently.

The next step in this process is to create the CPTs for each node (threat, APT, and asset) to enable our model to function effectively.

Table 7
Assets, CVEs, CAPECs, techniques.

Asset	CVE	Detailed CAPEC	Standard CAPEC	MITRE ATT&CK technique
VPN	CVE-2019–11510	64, 76, 78	CAPEC-267	T1027 (Obfuscated Files or Information)
Web Server	CVE-2007–6388	85	CAPEC-580	T1082 (System Information Discovery)

Table 8
Assets, CVEs, CAPECs, and numerical likelihood of attack.

Asset	CVE	CAPEC	Likelihood of Attack	Numerical CAPEC value
VPN	CVE-2019–11510	126	high	0.8
WebServer	CVE-2007–6388	588	high	0.8
WorkStation	CVE-2017–0143	10	high	0.8
WorkStation	CVE-2017–8692	10	high	0.8
HMI	CVE-2011–4875	10	high	0.8
HMI	CVE-2011–4876	126	high	0.8
HMI	CVE-2011–4877	10	high	0.8
HDB	CVE-2017–8917	110	high	0.8
PLC	CVE-2017–7575	116	high	0.8

Table 9
Assets, CVEs, CAPECs, and final score.

Asset	CVE	EPSS	CAPEC	Final score
VPN	2019–11510	0.974	0.8	0.779
WebS	2007–6388	0.843	0.8	0.674
WS	2017–0143	0.96	0.8	0.768
WS	2017–8692	0.163	0.8	0.130
HMI	2011–4875	0.307	0.8	0.246
HMI	2011–4876	0.032	0.8	0.026
HMI	2011–4877	0.045	0.8	0.036
HDB	2017–8917	0.975	0.8	0.780
PLC	2017–7575	0.114	0.8	0.091

In this step, we employ the use of AND/OR gates, as described in Section 4.3. The logical relationships between the nodes are defined as follows:

1. T1 OR APT(VPN)
2. T2 OR APT(WebS)
3. (T3 OR T4) AND (VPN OR WebS)
4. T8 AND WS
5. (T5 OR T6 OR T7) AND WS
6. T9 AND (HDB OR HMI)

This approach is adopted to reflect the potential attack paths an external attacker might use to gain access to the PLC. By structuring the CPTs in this manner, we accurately model the logical dependencies and interactions between the various threats (and their associated vulnerabilities) and asset nodes within the Bayesian network, facilitating a realistic simulation of attack scenarios.

Since we have constructed the Bayesian network topology and defined the relationships between the nodes, the final step in this process is to create the necessary CPTs for each node. To accomplish this, we must define the two possible states: S_0, which represents the state where there is no attack, and S_1, which represents the state of an attack. These states will be used to populate the CPTs, enabling our Bayesian Threat Probability Module to accurately reflect the likelihood of each node being in an attack or non-attack state based on the logical relationships and dependencies previously established. Table 12 presents the CPT for nodes T1, T2, APT (VPN), and APT (WebS). These nodes do not have any parent nodes, meaning their scores are determined solely by their own state.

Table 13 presents the CPT table for VPN node which has two parents, the T1 node and APT (VPN) node. Table 14 presents the CPT table for WebS node which also has two parents, the T2 node and APT(WebS) node.

Table 15 presents the CPT table for WS node which has 4 parents, the T3, T4, VPN and WebS nodes.

Table 16 presents the CPT table for HMI node which also have 4 parents, the T5, T6, T7 and WS nodes, while Table 17 presents the CPT table for HDB node which has 2 parents, the T8 and WS node. Lastly Table 18 presents the CPT table for PLC node, which has 3 parents HDB, HMI and T9 nodes.

6. Results

Finally, we present the results obtained after the successful execution of our Bayesian network. The Bayesian network was constructed using the GeNIe Modeler (Anon, 2024d), a tool freely available for academic use and widely adopted by the scientific community for constructing Bayesian networks in cybersecurity and other domains (Wang et al., 2023; He et al., 2021; Abbasi Kharajou et al., 2024)

Fig. 6 illustrates the Bayesian network constructed using the GeNIe Modeler software. Additionally, for demonstration purposes, we present a piechart along with the probability distribution for the PLC, which is the final node within our topology, in Fig. 7, after the successful execution of GeNIe.

Table 19 shows the updated (posterior) threat probability scores for each asset, specifically representing the probability of each asset being in the S_1 state (indicating a successful attack).

The PLC asset has the lowest posterior threat score, indicating the lowest probability of a successful attack at this node. Our model accounts for the network topology and the potential movements of attackers within the network. Consequently, for an attacker to initiate an attack on the PLC asset, they must first successfully exploit all preceding vulnerabilities of other connected assets. In this context, the already low EPSS score of 0.114 further underscores that the successful exploitation of the PLC is a rare occurrence. Conversely, the Web Server asset has the highest threat score. This is expected, as its original EPSS score is significantly high (0.843), and it is directly affected by the APT

Table 10
APT groups, area of interest, and industry of interest.

APT group	Area of interest	Industry of interest
BlackOasis	United Nations	Prominent figures, opposition bloggers, activists, regional news correspondents, and think tanks.
Earth Lusca	Australia, China, Hong Kong, Mongolia, Nepal, the Philippines, Taiwan, Thailand, Vietnam, the United Arab Emirates, Nigeria, Germany, France, and the United States	Government institutions, news media outlets, gambling companies, educational institutions, COVID-19 research organizations, telecommunications companies, religious movements banned in China, and cryptocurrency trading platforms.
Backdoor Diplomacy	Africa, Europe, the Middle East, and Asia	Ministries of Foreign Affairs and telecommunication companies.

Table 11
Outcome of step 2.

Asset	CVE	Bridge	Threat score	Threat name	APT groups Indicator
VPN	CVE-2019–11510	YES	0.779	T1	0.3
WebServer	CVE-2007–6388	YES	0.674	T2	0.9
WorkStation	CVE-2017–0143	NO	0.768	T3	NO
WorkStation	CVE-2017–8692	NO	0.130	T4	NO
HMI	CVE-2011–4875	NO	0.246	T5	NO
HMI	CVE-2011–4876	NO	0.026	T6	NO
HMI	CVE-2011–4877	NO	0.036	T7	NO
HDB	CVE-2017–8917	NO	0.780	T8	NO
PLC	CVE-2017–7575	NO	0.091	T9	NO

Table 12
CPT for T1, T2, and APT nodes.

	S0	S1
T1	0.221	0.779
T2	0.326	0.674
APT (VPN)	0.3	0.7
APT (WebS)	0.1	0.9

Table 13
CPT for VPN.

T1	APT	S0	S1
0	0	1	0
0	1	1	0
1	0	0.221	0.779
1	1	0.155	0.845

Table 14
CPT for WebS.

T2	APT	S0	S1
0	0	1	0
0	1	1	0
1	0	0.326	0.674
1	1	0.033	0.967

Table 15
CPT for WS.

VPN	Web	T3	T4	S0	S1
0	0	0	0	1	0
0	0	0	1	1	0
0	0	1	0	1	0
0	0	1	1	1	0
0	1	0	0	1	0
0	1	0	1	0.87	0.13
0	1	1	0	0.232	0.768
0	1	1	1	0.202	0.798
1	0	0	0	1	0
1	0	0	1	0.87	0.13
1	0	1	0	0.232	0.768
1	0	1	1	0.202	0.798
1	1	0	0	1	0
1	1	0	1	0.87	0.13
1	1	1	0	0.232	0.768
1	1	1	1	0.202	0.798

Table 16
CPT for HMI.

WS	T5	T6	T7	S0	S1
0	0	0	0	1	0
0	0	0	1	1	0
0	0	1	0	1	0
0	0	1	1	1	0
0	1	0	0	1	0
0	1	0	1	1	0
0	1	1	0	1	0
0	1	1	1	1	0
1	0	0	0	1	0
1	0	0	1	0.964	0.036
1	0	1	0	0.974	0.026
1	0	1	1	0.939	0.061
1	1	0	0	0.754	0.246
1	1	0	1	0.727	0.273
1	1	1	0	0.734	0.266
1	1	1	1	0.708	0.292

Table 17
CPT for HDB.

WS	T8	S0	S1
0	0	1	0
0	1	1	0
1	0	1	0
1	1	0.22	0.78

Table 18
CPT for PLC.

HDB	HMI	T9	S0	S1
0	0	0	1	0
0	0	1	1	0
0	1	0	1	0
0	1	1	0.909	0.091
1	0	0	1	0
1	0	1	0.909	0.091
1	1	0	1	0
1	1	1	0.909	0.091

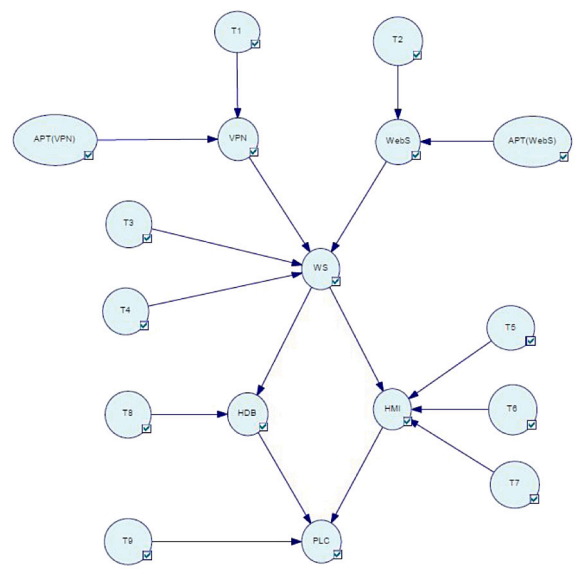

Fig. 6. GeNIe modeler Bayesian network.

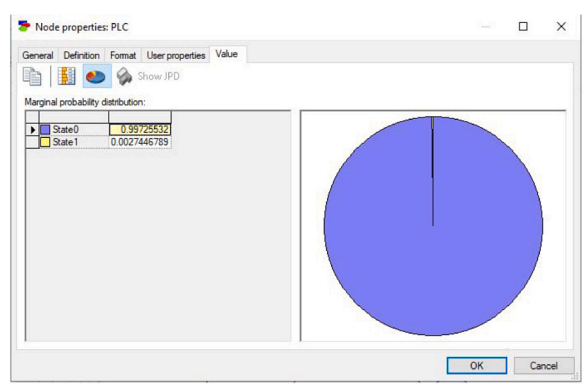

Fig. 7. GeNIe result at PLC.

Group Indicator — APT(WebS), which is also high (0.9). Additionally, the exploitation of WebS does not require the prior successful exploitation of other assets, unlike the PLC, as WebS is positioned at the top of the network topology. Another noteworthy observation is that the Web Server (WebS) asset has a higher threat score compared to the VPN asset, despite the VPN having a higher EPSS score (0.974) than WebS (0.843). This outcome is influenced by the APT Group Indicators, as the APT Group Indicator associated with WebS is higher (0.9) than the one connected to the VPN (0.1).

After calculating the threat score for each asset, the next step is to determine the impact score. The specific impact scale described earlier, selected for demonstration purposes, is used for this process. To

Table 19
Asset and updated threat scores.

Asset	Updated threat score
VPN	0.622
WebS	0.632
WS	0.514
HDB	0.313
HMI	0.048
PLC	0.0027

Table 20
Risk values per asset.

Asset	Threat score	Impact score	Risk
VPN	0.622	2	1.244
WEB	0.632	2	1.644
WS	0.514	2	1.028
HDB	0.313	2	0.616
HMI	0.048	2	0.096
PLC	0.0027	2	0.0054

maintain focus on threat probability and its influence on risk, a uniform impact score has been assigned to all assets. For the purposes of this use case, each asset is assigned a medium impact score. This approach allows the analysis to center on variations in threat probability. Given that the maximum threat (probability) score provided by the Bayesian Threat Probability Module is 1, and the maximum impact score is 3, the resulting risk scale ranges from 0 to 3. Table 20 presents the risk outcomes for each asset, along with all the data (posterior probability, impact) utilized in this estimation.

Our model successfully updated the probabilities of each node by accounting for the unique network topology of the target environment, potential attacker movements, detected vulnerabilities on each asset, and their relationships. It also considered the dependencies between nodes, the identified EPSS scores, CAPEC's likelihood of attack values and any APT Groups that may target this specific environment.

6.1. Introduction of firewall

In the original scenario, no security mechanisms were in place, allowing our model to estimate the posterior threat probability and associated risk without any defensive measures. In this subsection, we introduce a firewall within the enterprise layer. This firewall is designed to protect assets within the enterprise layer, which includes the VPN, the Web Server, and the Workstation. This firewall protects assets within the enterprise layer and does not directly affect assets in the industrial or physical layers.

We assume that the installed firewall has a detection and prevention rate of 80%, meaning that 80% of malicious activities can be detected and blocked. Based on this assumption, we restructured our Bayesian network by adding an additional node, as illustrated in Fig. 8. Given the scenario description, the firewall node is directly connected to the VPN, Web Server, and Workstation nodes. Consequently, the CPTs for these nodes needed to be reconstructed. Table 21 presents the CPT for the VPN, Table 22 presents the CPT for the Web Server, and Table 23 presents the CPT for the Workstation given the Firewall.

Given that new CPTs were created for this scenario, we re-executed our Bayesian network using the same simulator. Table 24 presents the posterior threat probability scores generated by our Bayesian Threat Probability Module for both the original scenario (without a firewall) and the modified scenario (with a firewall). The results indicate a reduction in threat probability, ranging from 15.92% at the VPN to 22.22% at the PLC, demonstrating that the installation of a security mechanism (firewall) effectively reduces threat scores across all network assets by an average of 18.49%. This suggests that the threat score of assets is closely linked to the detection and prevention capabilities of

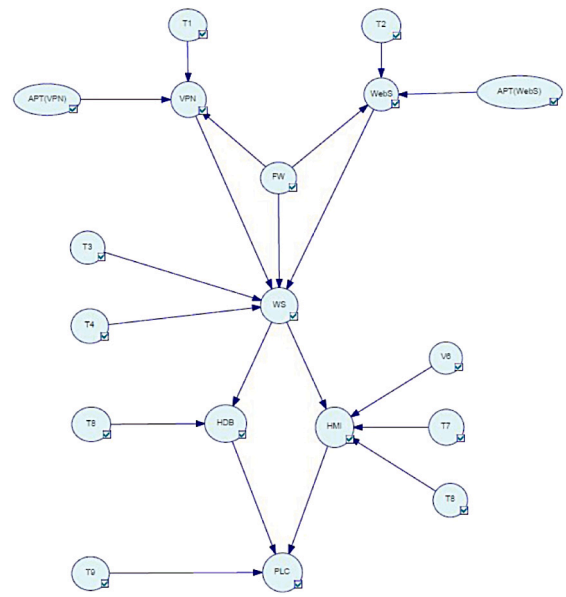

Fig. 8. GeNIe modeler Bayesian network with firewall.

Table 21
CPT for VPN - FW.

T1	APT (VPN)	FW	S0	S1
0	0	0	1	0
0	0	1	1	0
0	1	0	1	0
0	1	1	1	0
1	0	0	0.221	0.779
1	0	1	0.845	0.155
1	1	0	0.155	0.845
1	1	1	0.831	0.169

Table 22
CPT for WebS - FW.

T2	APT(WebS)	FW	S0	S1
0	0	0	1	0
0	0	1	1	0
0	1	0	1	0
0	1	1	1	0
1	0	0	0.326	0.674
1	0	1	0.865	0.135
1	1	0	0.033	0.967
1	1	1	0.807	0.193

the security mechanism. In this scenario, since the firewall is able to detect and block 80% of malicious activities, it results in an average threat probability reduction of 18.49%. It is noteworthy that the installation of the firewall within the enterprise layer most significantly impacts the threat probability score not of the directly connected assets, but of the PLC, which is located deeper within the network. Although the PLC's threat score is already very low, indicating almost zero chances of a successful attack, these findings could be valuable in scenarios where the PLC asset shows higher probabilities of being successfully attacked.

6.2. Influence of APT groups

In this subsection, we present findings on the influence of APT Groups in the posterior threat score. As shown in Table 25, APT Group Indicators significantly impact the posterior probability scores of the assets, with increases ranging from 2.41% for the VPN to 28.16% for the Web Server (WebS). These results are based on the value of each APT Group Indicator, demonstrating that high-value APT Group Indicators

Table 23
CPT for WS - FW.

VPN	WebS	T3	T4	FW	State0	State1
0	0	0	0	0	1	0
0	0	0	0	1	1	0
0	0	0	1	0	1	0
0	0	0	1	1	1	0
0	0	1	0	0	1	0
0	0	1	0	1	1	0
0	0	1	1	0	1	0
0	0	1	1	1	1	0
0	1	0	0	0	1	0
0	1	0	0	1	1	0
0	1	0	1	0	0.87	0.13
0	1	0	1	1	0.974	0.026
0	1	1	0	0	0.232	0.768
0	1	1	0	1	0.846	0.154
0	1	1	1	0	0.202	0.798
0	1	1	1	1	0.84	0.16
1	0	0	0	0	1	0
1	0	0	0	1	1	0
1	0	0	1	0	0.87	0.13
1	0	0	1	1	0.974	0.026
1	0	1	0	0	0.232	0.768
1	0	1	0	1	0.846	0.154
1	0	1	1	0	0.202	0.798
1	0	1	1	1	0.84	0.16
1	1	0	0	0	1	0
1	1	0	0	1	1	0
1	1	0	1	0	0.87	0.13
1	1	0	1	1	0.974	0.026
1	1	1	0	0	0.232	0.768
1	1	1	0	1	0.846	0.154
1	1	1	1	0	0.202	0.798
1	1	1	1	1	0.84	0.16

Table 24
Comparison of threat scores without and with firewall.

Asset	Without FW	With FW (0.8)	Decrease (%)
VPN	0.622	0.523	15.92%
WEB	0.632	0.531	15.98%
WS	0.514	0.417	18.87%
HDB	0.313	0.253	19.17%
HMI	0.048	0.039	18.75%
PLC	0.0027	0.0021	22.22%

Table 25
Comparison of threat scores without and with APT groups.

Asset	Without APT	With APT	Increase %
VPN	0.607	0.622	2.41
WEB	0.454	0.632	28.16
WS	0.469	0.514	8.75
HDB	0.285	0.313	9.27
HMI	0.044	0.048	8.33
PLC	0.0025	0.0027	7.4

can strongly affect directly connected assets (such as WebS) compared to those with lower APT Group Indicator values. Additionally, the integration of APT Group Indicators leads to an overall increase in threat scores across all assets, with an average rise of 10.72%.

Our results demonstrate that the integration of APT Group Indicators, which represent the likelihood of an attack by an APT for a specific target, based on target-specific information such as location, industry, and detected CVEs, leads to an increase in the threat score. This effect is particularly noticeable for nodes (bridge nodes) that are directly connected to, and thus directly influenced by, APT Group Indicator nodes. The threat score of these bridge nodes is directly dependent on the score of the connected APT Group Indicator nodes. As our findings indicate, the higher the score of an APT Indicator node, the greater the increase in the threat score of the associated bridge node.

Another significant finding from our simulations is the observed relationship between the prior threat score, APT Group Indicators, and the posterior threat score. Specifically, when both bridge assets (VPN and WebS) share the same APT Group Indicator with a score of 0.9, the posterior threat score for VPN is 0.746. Given that the prior threat score of VPN is 0.607, this indicates that the APT Group Indicator raised the posterior threat score of VPN by 18.62%. However, this increase is smaller compared to the 28.16% rise in WebS, which had a lower prior threat score (0.454) than VPN (0.607). This suggests that the lower the prior threat score, the greater the influence of the APT Group Indicator on the posterior threat score. Consequently, we can infer that even minor or less critical threats can become significant for organizations if they attract the interest of APT Groups.

Thus, our model demonstrates that the probability of a successful attack, and consequently, the associated risk, can be influenced in cases when an organization is a potential target of APT groups.

7. Discussion and limitations

The proposed methodology considers various factors from both external sources and the internal environment to dynamically estimate the threat score, which is used for risk estimations. Detected vulnerabilities serve as the basis for extracting necessary data, which is integral to calculating the overall risk within our model. The vulnerability mitigation is a critical factor within SCADA environments (Hellström, 2007). One common approach to mitigating vulnerabilities — and thus reducing or eliminating risk, as many risk assessment methodologies rely on the relationship between risk and vulnerability (Lambrinoudakis et al., 2022) — is to apply patches.

However, within SCADA environments, legacy systems often pose significant challenges when it comes to updates or patching (Furnell et al., 2014). Given these challenges, a more effective solution to risk reduction might involve methods to mitigate the impact of potential attacks (Vieira et al., 2020) or reduce the probability of threats (Schechter, 2020). Since our methodology is capable of dynamically updating threat probabilities, we chose to demonstrate threat reduction, and consequently, risk by installing a firewall. This outcome aligns with existing research, which shows that cybersecurity mechanisms and controls can effectively lower cyber risk (Kumar, 2023), Khan (2023).

While our approach can effectively estimate risk when vulnerabilities (CVEs) are identified, it operates under the assumption that the successful exploitation of a vulnerability will grant an attacker access to the system, enabling them to advance to the next phase of the attack (i.e., targeting the subsequent node). However, this assumption may not always hold true, as different vulnerabilities may affect assets differently (Peterson, 2010), and may lead to different types of attacks (Chillur et al., 2022). A limitation of our work is that it does not consider the specific characteristics or details of each vulnerability. It assumes that each detected vulnerability provides the attacker with a probability of gaining access to the node where the vulnerability is identified.

While we could analyze each identified vulnerability and develop distinct attack scenarios for each (Branescu et al., 2024), doing so would impede our model's ability to estimate overall risk per asset. Our approach, in contrast, provides a comprehensive risk estimation for each asset, enabling security analysts to understand the total risk associated with each asset without creating multiple, disparate risk scenarios. This focus on aggregate risk estimation facilitates a clearer understanding of an asset's overall security posture.

Another limitation of the proposed solution is its inability to integrate real-time attack data, as seen in other DRA approaches (Cam, 2015; Zhang et al., 2016; Huang et al., 2017). Consequently, our model lacks the capability to adapt to ongoing changes in real-time and, therefore, cannot provide corresponding risk assessments that reflect the evolving threat landscape. However, the novelty of our methodology

lies in its integration of the EPSS, which is inherently proactive, as it provides probabilistic estimates of vulnerability exploitation within the next 30 days. By incorporating EPSS into a dynamic risk assessment framework that also considers the unique characteristics of the target environment, our model can generate tailored, forward-looking risk assessments over a 30-day horizon.

Compared to existing DRA approaches, our methodology is entirely independent of subjective expert opinions (Henshel et al., 2016; Zhang et al., 2016), as it relies solely on objective data for constructing the Bayesian network. Furthermore, this is the first study to integrate EPSS data into a dynamic risk assessment framework, a significant advancement given that EPSS provides a more accurate and threat-focused estimation of exploitability than conventional DRA methods based on CVSS metrics (Zhou et al., 2023; Lyu et al., 2020). Bayesian networks, as a probabilistic modeling technique, are used to update probability distributions based on incoming data. In the context of cyber risk assessment, they dynamically adjust the threat vector rather than the vulnerability vector. As EPSS data pertains directly to the threat vector, it is more suitable for cyber threat modeling than CVSS data, which primarily addresses vulnerability-related factors. Additionally, our methodology incorporates attack likelihood, a threat-related metric from CAPEC, to enhance the accuracy of risk estimation.

Similar to most DRA methodologies that utilize Bayesian networks, our approach considers the network topology of the target environment when constructing the Bayesian model. However, a key contribution of this study is its detailed examination of the influence of security mechanisms, such as firewalls, in dynamic cyber risk assessment. Moreover, this is the first study to assess the impact of APT groups within a dynamic risk assessment framework.

Several studies have examined APT groups (Li et al., 2024; Chen et al., 2019; Cai et al., 2020) and optimal defense strategies (Taylor et al., 2019; Mwiki et al., 2019). However, the relationship between APT groups and cyber risk within the context of cyber risk management remains unclear. Specifically, while risk is typically calculated by multiplying threat by impact, and, in some cases, vulnerability, the nuances of how these elements interact with APT groups require further exploration.

Our results regarding the influence of APT Groups with the context of cyber risk assessment, partially align with the findings of Mohamed et al. Ahmed et al. (2022), who proposed a cyber risk assessment methodology to evaluate the likelihood of success for APT Groups' attacks using the MITRE ATT&CK framework. Their results indicated that the likelihood of attack success, and consequently risk, may vary based on the threat actor's capabilities and the level of security controls in place. While our methodology does not distinguish between APT Groups based on their capabilities, it does account for the fact that the threat score (threat likelihood) varies depending on the number of APT Groups showing interest in the specific target.

Despite the fact that our methodology can proactively and dynamically update risk values, it is limited to scenarios where a random adversary or an APT Group attempts to infiltrate the target network from the outside (external attacker), specifically targeting nodes accessible via the internet. Another limitation of our methodology is that it does not account for attacks that may occur through the supply chain Ghadge et al. (2019), Yeboah-Ofori and Islam (2019), nor does it consider attacks originating from insider threat actors (Greitzer et al., 2008). Such attacks could have a direct impact on the probability and, consequently, on the risk scores of assets located deep within the network, such as the PLC.

8. Future work

In future work, we plan to integrate real-time attack evidence into our model to enhance its ability to function both reactively — responding to incidents as they occur — and proactively—anticipating potential threats before they materialize. This advancement will strengthen the model's capability to provide dynamic cyber risk assessments, thereby improving the overall cybersecurity posture of organizations.

In regard to the integration of APTs into the Bayesian network, we plan to incorporate live CTI data from relevant sources, such as the Malware Information Sharing Platform (MISP). This integration will enable real-time updates to threat assessments, utilizing the most recent and advanced information available. This process will further enhance the proactive capabilities of our model, allowing for dynamic risk updates based on relevant CTI from similar organizations.

Additionally, we plan to address insider threats and supply chain attacks in future work. The integration of these additional threat vectors, alongside CTI and real-time attack evidence, will significantly increase the volume of data processed by our model. As a result, rather than relying solely on a Bayesian network for analysis, we may adopt a neural network-based approach. This transition would improve the model's efficiency and effectiveness in handling large-scale datasets while maintaining high accuracy in cyber risk assessment.

Finally, we presented a case study demonstrating the methodology's application in an artificial SCADA environment. Given the critical nature of such infrastructures, we recognize the importance of evaluating the methodology's applicability in real-world scenarios. Therefore, as a next step, we plan to conduct tests in a simplified organizational environment, such as a small business, to assess its effectiveness under practical conditions.

9. Conclusions

In this article, we presented a dynamic risk assessment methodology designed to estimate cyber risk. The proposed model gathers data from cybersecurity-related open sources and integrates it with information from the organization's internal environment using a Bayesian network. This integration enables the dynamic estimation of the threat score, which is utilized alongside the impact to calculate overall risk. By incorporating EPSS data, our model provides proactive risk estimations tailored to specific organization. Additionally, we offer valuable insights into the impact of security mechanisms on threat reduction. Furthermore, we evaluate the influence of APT groups on threat score. The effectiveness of the proposed methodology is demonstrated through a comprehensive use case, showcasing its practical application and efficacy.

CRediT authorship contribution statement

Pavlos Cheimonidis: Writing – original draft, Validation, Methodology, Investigation, Conceptualization. **Konstantinos Rantos:** Writing – review & editing, Validation, Supervision.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data availability

The data used for this paper was obtained from cybersecurity-related open sources, including the NVD, CAPEC, and MITRE ATT&CK.

References

Abbasi Kharajou, B., Ahmadi, H., Rafiei, M., Moradi Hanifi, S., 2024. Quantitative risk estimation of CNG station by using fuzzy bayesian networks and consequence modeling. Sci. Rep. 14 (1), 4266.

Ahmed, M., Panda, S., Xenakis, C., Panaousis, E., 2022. MITRE ATT& CK driven cyber risk assessment. In: Proceedings of the 17th International Conference on Availability, Reliability and Security. pp. 1–10.

Anon, 2024a. Common Attack Pattern Enumeration and Classification (CAPEC™). www.capec.mitre.org/. (Accessed 11 August 2024).

Anon, 2024b. Common Weakness Enumeration (CWE). www.cwe.mitre.org/. (Accessed 11 August 2024).

Anon, 2024c. Exploit Prediction Scoring System (EPSS). www.first.org/epss/. (Accessed 13 August 2024).

Anon, 2024d. GeNIe modeler and SMILE engine. www.bayesfusion.com/genie/. (Accessed 06 August 2024).

Anon, 2024e. National Vulnerability Database (NVD). www.nvd.nist.gov/. (Accessed 10 August 2024).

Anon, 2024f. Nessus vulnerability management. www.tenable.com/products/nessus. (Accessed 06 August 2024).

Branescu, I., Grigorescu, O., Dascalu, M., 2024. Automated mapping of common vulnerabilities and exposures to MITRE ATT&CK tactics. Information 15 (4), 214.

Cai, Y., Gu, Z., Wang, L., Li, S., Han, W., 2020. An APT group knowledge model based on MDATA. In: Proceedings of the 2020 International Conference on Cyberspace Innovation of Advanced Technologies. http://dx.doi.org/10.1145/3444370.3444600.

Cam, H., 2015. Risk assessment by dynamic representation of vulnerability, exploitation, and impact. In: Proc. SPIE 9458, Cyber Sensing 2015. SPIE, 945809. http://dx.doi.org/10.1117/12.2177405, (26 May 2015).

Chandia, R., Gonzalez, J., Kilpatrick, T., Papa, M., Shenoi, S., 2008. Security strategies for SCADA networks. In: Critical Infrastructure Protection 1. Springer, pp. 117–131.

Cheimonidis, P., Rantos, K., 2023. Dynamic risk assessment in cybersecurity: A systematic literature review. Futur. Internet 15 (10), 324. http://dx.doi.org/10.3390/fi15100324.

Chen, C.-M., Lai, G.-H., Wen, D.-W.M., 2019. Evolution of advanced persistent threat (APT) attacks and actors. In: Chang, C.-Y., Lin, C.-C., Lin, H.-H. (Eds.), New Trends in Computer Technologies and Applications. Springer Singapore, Singapore, pp. 76–81.

Chillur, N., Patel, A., Patel, S., Swain, D., 2022. Deep analysis of attacks and vulnerabilities of web security. In: Singh, P.K., Wierzchoń, S.T., Chhabra, J.K., Tanwar, S. (Eds.), Futuristic Trends in Networks and Computing Technologies. Springer Nature Singapore, Singapore, pp. 1087–1097.

Dimitriadis, A., Flores, J.L., Kulvatunyou, B., Ivezic, N., Mavridis, I., 2020. ARES: Automated risk estimation in smart sensor environments. Sensors 20 (16), http://dx.doi.org/10.3390/s20164617.

Freund, J., Jones, J., 2014. Measuring and Managing Information Risk: A FAIR Approach. Butterworth-Heinemann.

Furnell, S., Niekerk, J., Clarke, N., 2014. The price of patching. Comput. Fraud. Secur. 2014, 8–13. http://dx.doi.org/10.1016/S1361-3723(14)70521-4.

Ghadge, A., Weib, M., Caldwell, N., Wilding, R., 2019. Managing cyber risk in supply chains: a review and research agenda. Supply Chain Manage.: An Int. J. http://dx.doi.org/10.2139/SSRN.3426030.

Greitzer, F., Moore, A., Cappelli, D.M., Andrews, D., Carroll, L., Hull, T.D., 2008. Combating the insider cyber threat. IEEE Secur. Priv. 6, http://dx.doi.org/10.1109/MSP.2008.8.

He, L., Tang, T., Hu, Q., Cai, Q., Li, Z., Tang, S., Wang, Y., 2021. Integration of interpretive structural modeling with fuzzy Bayesian network for risk assessment of tunnel collapse. Math. Probl. Eng. 2021 (1), 7518284.

Hellström, T., 2007. Critical infrastructure and systemic vulnerability: Towards a planning framework. Saf. Sci. 45 (3), 415–430. http://dx.doi.org/10.1016/j.ssci.2006.07.007.

Hemberg, E., Kelly, J., Shlapentokh-Rothman, M., Reinstadler, B., Xu, K., Rutar, N., O'Reilly, U.-M., 2020. BRON - Linking attack tactics, techniques, and patterns with defensive weaknesses, vulnerabilities and affected platform configurations. ArXiv abs/2010.00533.

Henley, E.J., Kumamoto, H., 2000. Probablistic Risk Assessment and Management for Engineers and Scientists, second ed. Wiley-IEEE Press.

Henshel, D., Alexeev, A., Cains, M., Rowe, J., Cam, H., Hoffman, B., Neamtiu, I., 2016. Modeling cybersecurity risks: Proof of concept of a holistic approach for integrated risk quantification. In: 2016 IEEE Symposium on Technologies for Homeland Security. HST, pp. 1–5. http://dx.doi.org/10.1109/THS.2016.7568937.

Huang, K., Zhou, C., Tian, Y.-C., Tu, W., Peng, Y., 2017. Application of Bayesian network to data-driven cyber-security risk assessment in SCADA networks. In: 2017 27th International Telecommunication Networks and Applications Conference. ITNAC, pp. 1–6.

International Organization for Standardization, 2018. ISO 31000:2018 - Risk Management – Guidelines. Available at: https://www.iso.org/standard/65694.html. [Accessed 10 December 2024].

Jensen, F., Nielsen, T., 2007. Bayesian Networks and Decision Graphs, second ed. Springer.

Johnson, P., Lagerström, R., Ekstedt, M., Franke, U., 2018. Can the common vulnerability scoring system be trusted? A Bayesian analysis. IEEE Trans. Dependable Secur. Comput. 15 (6), 1002–1015.

Joint Task Force Transformation Initiative, 2018. Risk management framework for information systems and organizations: A system life cycle approach for security and privacy. Available at: http://dx.doi.org/10.6028/NIST.SP.800-37r2. [Accessed 15 November 2024].

Kang, D.-J., Lee, J.-J., Kim, S.-J., Park, J.-H., 2009. Analysis on cyber threats to SCADA systems. In: Transmission & Distribution Conference & Exposition: Asia and Pacific, 2009. IEEE, pp. 1–4. http://dx.doi.org/10.1109/TD-ASIA.2009.5357008.

Kaplan, S., Garrick, B.J., 1981. On the quantitative definition of risk. Risk Anal. 1 (1), 11–27.

Khan, M.J., 2023. Securing network infrastructure with cyber security. World J. Adv. Res. Rev. http://dx.doi.org/10.30574/wjarr.2023.17.2.0308.

Kumar, A.R., 2023. A review article on cyber security. Int. J. Sci. Res. Eng. Manag. http://dx.doi.org/10.55041/ijsrem25428.

Kuppa, A., Aouad, L.M., Le-Khac, N.-A., 2021. Linking CVE's to MITRE ATT CK techniques. In: Proceedings of the 16th International Conference on Availability, Reliability and Security. http://dx.doi.org/10.1145/3465481.3465758.

Lambrinoudakis, C., Gritzalis, S., Xenakis, C., Katsikas, S., Karyda, M., Tsochou, A., Papadatos, K., Rantos, K., Pavlosoglou, Y., Gasparinatos, S., Pantazis, A., 2022. Interoperable EU Risk Management Framework: Methodology for and Assessment of Interoperability Among Risk Management Frameworks and Methodologies. Tech. Rep., European Union Agency for Cybersecurity (Publications Office), http://dx.doi.org/10.2824/07253.

Li, J., Liu, J., Zhang, R., 2024. Advanced persistent threat group correlation analysis via attack behavior patterns and rough sets. Electronics 13 (6), http://dx.doi.org/10.3390/electronics13061106.

Linkov, I., Anklam, E., Collier, Z., DiMase, D., Renn, O., 2014. Risk-based standards: Integrating top-down and bottom-up approaches. Environ. Syst. Decis. 34 (1), 134–137. http://dx.doi.org/10.1007/s10669-014-9488-3.

Lyu, X., Ding, Y., Yang, S.-H., 2020. Bayesian network based C2P risk assessment for cyber-physical systems. IEEE Access 8, 88506–88517. http://dx.doi.org/10.1109/ACCESS.2020.2993614.

Mkrtchyan, L., Podofillini, L., Dang, V., 2016. Methods for building conditional probability tables of Bayesian belief networks from limited judgment: An evaluation for human reliability application. Reliab. Eng. Syst. Saf. 151, 93–112. http://dx.doi.org/10.1016/j.ress.2016.01.004.

Mwiki, H., Dargahi, T., Dehghantanha, A., Choo, K.-K.R., 2019. Analysis and triage of advanced hacking groups targeting western countries critical national infrastructure: APT28, RED October, and regin. Adv. Sci. Technol. Secur. Appl. http://dx.doi.org/10.1007/978-3-030-00024-0-12.

Naumov, S., Kabanov, I., 2016. Dynamic framework for assessing cyber security risks in a changing environment. In: Proceedings of the 2016 International Conference on Information Science and Communications Technologies. ICISCT, IEEE, Tashkent, Uzbekistan, pp. 1–4.

Nicholson, A., Webber, S., Dyer, S., Patel, T., Janicke, H., 2012. SCADA security in the light of cyber-warfare. Comput. Secur. 31, 418–436. http://dx.doi.org/10.1016/j.cose.2012.02.009.

Peng, Y., Huang, K., Tu, W., Zhou, C., 2018a. A model-data integrated cyber security risk assessment method for industrial control systems. In: 2018 IEEE 7th Data Driven Control and Learning Systems Conference. DDCLS, pp. 344–349. http://dx.doi.org/10.1109/DDCLS.2018.8516022.

Peng, Y., Huang, K., Tu, W., Zhou, C., 2018b. A model-data integrated cyber security risk assessment method for industrial control systems. In: 2018 IEEE 7th Data Driven Control and Learning Systems Conference. DDCLS, IEEE, pp. 344–349.

Peterson, P.A., 2010. Cryptkeeper: Improving security with encrypted RAM. In: 2010 IEEE International Conference on Technologies for Homeland Security. HST, IEEE, pp. 120–126.

Poolsappasit, N., Dewri, R., Ray, I., 2012. Dynamic security risk management using Bayesian attack graphs. IEEE Trans. Dependable Secur. Comput. 9 (1), 61–74.

Qin, Y., Peng, Y., Huang, K., Zhou, C., Tian, Y.-C., 2021. Association analysis-based cybersecurity risk assessment for industrial control systems. IEEE Syst. J. 15, 1423–1432.

Ren, C., Xu, Y., Dai, B., Zhang, R., 2021. An integrated transfer learning method for power system dynamic security assessment of unlearned faults with missing data. IEEE Trans. Power Syst. 36 (5), 4856–4859.

Sánchez-Zas, C., Villagrá, V.A., Vega-Barbas, M., Larriva-Novo, X., Moreno, J.I., Berrocal, J., 2023. Ontology-based approach to real-time risk management and cyber-situational awareness. Future Gener. Comput. Syst. 141, 462–472. http://dx.doi.org/10.1016/j.future.2022.12.006.

Schechter, S., 2020. Toward econometric models of the security risk from remote attacks. IEEE Secur..

Tariq, N., Asim, M., Khan, F.A., 2019. Securing SCADA-based critical infrastructures: Challenges and open issues. Procedia Comput. Sci. 155, 612–617. http://dx.doi.org/10.1016/j.procs.2019.08.086, The 16th International Conference on Mobile Systems and Pervasive Computing (MobiSPC 2019), The 14th International Conference on Future Networks and Communications (FNC-2019), The 9th International Conference on Sustainable Energy Information Technology.

Taylor, P.J., Dargahi, T., Dehghantanha, A., 2019. Analysis of apt actors targeting IoT and big data systems: Shell_crew, nettraveler, projectsauron, copykittens, volatile cedar and transparent tribe as a case study. Handb. Big Data Iot Secur. 257–272.

The MITRE Corporation, 2024. MITRE. www.mitre.org/. (Accessed 10 August 2024).

Vieira, A., Insua, D., Kosgodagan, A., 2020. Assessing and forecasting cybersecurity impacts. Decis. Anal. 17, 356–374. http://dx.doi.org/10.1287/deca.2020.0418.

Wang, F., Bian, J., Zheng, G., Li, M., Sun, X., Zhang, C., 2023. A modeling approach to the efficient evaluation and analysis of water quality risks in cold zone lakes: a case study of Chagan Lake in Northeast China. Environ. Sci. Pollut. Res. 30 (12), 34255–34269.

Wang, C., Fang, L., Dai, Y., 2010. A simulation environment for SCADA security analysis and assessment. In: 2010 International Conference on Measuring Technology and Mechatronics Automation, Vol. 1. IEEE, pp. 342–347.

Yadav, G., Paul, K., 2021. Architecture and security of SCADA systems: A review. Int. J. Crit. Infrastruct. Prot. 34, 100433.

Yeboah-Ofori, A., Islam, S., 2019. Cyber security threat modeling for supply chain organizational environments. Futur. Internet 11, 63. http://dx.doi.org/10.3390/FI11030063.

Zhang, Q., Zhou, C., Tian, Y.-C., Xiong, N., Qin, Y., Hu, B., 2018. A fuzzy probability Bayesian network approach for dynamic cybersecurity risk assessment in industrial control systems. IEEE Trans. Ind. Informatics 14 (6), 2497–2506. http://dx.doi.org/10.1109/TII.2017.2768998.

Zhang, Q., Zhou, C., Xiong, N., Qin, Y., Li, X., Huang, S., 2016. Multimodel-based incident prediction and risk assessment in dynamic cybersecurity protection for industrial control systems. IEEE Trans. Syst. Man Cybern.: Syst. 46 (10), 1429–1444. http://dx.doi.org/10.1109/TSMC.2015.2503399.

Zhou, B., Sun, B., Zang, T., Cai, Y., Wu, J., Luo, H., 2023. Security risk assessment approach for distribution network cyber physical systems considering cyber attack vulnerabilities. Entropy 25 (1), http://dx.doi.org/10.3390/e25010047.

Zhu, Q., Qin, Y., Zhou, C., Gao, W., 2018. Extended multilevel flow model-based dynamic risk assessment for cybersecurity protection in industrial production systems. Int. J. Distrib. Sens. Netw. 14 (6), http://dx.doi.org/10.1177/1550147718779564.